NKUST · DEVELOPER INTEGRATION

Web API 單一登入

JSON / 一次性票券 + PKCE；本專案自訂協定

對方需準備兩個瀏覽器入口：登入啟動頁及回呼頁；再由對方後端呼叫中央兌換 API。中央不會拿使用者帳密 POST 到對方網站。

1. **瀏覽器 → 接收系統 /login**
   產生 state、verifier，保存於後端且綁定當次瀏覽器登入請求。
2. **瀏覽器 → 中央 /ticket/authorize**
   帶 client_id、redirect_uri、state、challenge 與 S256。
3. **中央沿用登入或顯示登入頁**
   通過後核發最長 60 秒、只能使用一次的票券。
4. **中央 → 接收系統 /sso/callback**
   瀏覽器帶 ticket + state；接收端驗證 state、期限與瀏覽器關聯。
5. **接收系統後端 → POST /api/sso/v1/redeem**
   HTTP Basic + JSON ticket、redirect_uri、code_verifier。
6. **JSON 身分 → 接收系統本地登入**
   檢查 issuer、client_id、期限；以 issuer + sub 對應帳號並查權限。

申請設定

- 提供精確登入啟動網址與回呼網址；取得 Client ID、一次顯示的 Client Secret 與 SSO 基底網址。
- 請管理者在 SSO 系統設定選「Web API 單一登入」，啟用系統並勾選允許提供的身分欄位。
- Client Secret 與 verifier 只保存在接收系統後端；回呼完成清除登入請求並轉到不含 ticket 的網址。

> 本文件為目前開發版介面規格；正式網址、系統代碼、密鑰 / 憑證、授權欄位與測試帳號請向 SSO 管理者取得。
> example.edu 為示意位址，不可直接呼叫。

Web API 單一登入

JSON / 一次性票券 + PKCE；本專案自訂協定

請求欄位

端點 / 位置	欄位	規則
GET /ticket/authorize	client_id / redirect_uri	登記系統代碼 / 精確 HTTPS 回呼
Query	state	32～128 字元隨機 Base64Url；綁定瀏覽器及本次請求
Query	code_challenge	SHA-256(verifier) 的 Base64Url，43 字元、不含 =
Query	code_challenge_method	固定 S256
GET 接收端回呼	ticket / state	驗 state 後再兌換；ticket 是 43 字元 Base64Url
POST /api/sso/v1/redeem	HTTP Basic	帳號 Client ID；密碼 Client Secret
JSON body	ticket / redirect_uri / code_verifier	verifier 為本次原值，43～128 字元；Content-Type: application/json

成功回應：JSON 物件，不是 Bearer Token

欄位	型別 / 說明
issuer / client_id / sub	string；固定發行者、接收系統代碼、穩定使用者識別碼
authenticated_at / session_expires_at	number；Unix 秒（UTC），不是毫秒；建立中央登入時間與當下有效期限
username	string；校園登入帳號；學生為學號、教職員為員編
name	string；姓名
identity_type	string；身分類型，例如 student / employee；依實際來源，不自行推測
class_code	string；班級代碼
class_name	string；班級名稱
student_status_code	string；學籍狀態代碼
student_status_name	string；學籍狀態名稱
education_level_code	string；學制代碼
education_level_name	string；學制名稱

未授權的可選欄位會省略；學籍欄位還受 IncludeStudentProfile 設定限制。不要把缺少的欄位視為一定有值；缺少業務必需資料時拒絕或導向申請流程。

Web API 單一登入

JSON / 一次性票券 + PKCE；本專案自訂協定

登入啟動與回呼：語言中立示意

```
startLogin(browserSession):
    state = base64url(randomBytes(32))
    verifier = base64url(randomBytes(32))
    challenge = base64url(SHA256(ASCII(verifier)))
    savePending(browserSession, state, verifier, shortExpiry)
    redirect(SSO + "/ticket/authorize?" + urlEncode({
        client_id: CLIENT_ID, redirect_uri: CALLBACK,
        state: state, code_challenge: challenge,
        code_challenge_method: "S256" }))

callback(browserSession, ticket, state):
    pending = atomicallyTakePending(browserSession, state)
    require(pending exists and not expired)
    data = backendPostJson(SSO + "/api/sso/v1/redeem",
        basicAuth(CLIENT_ID, SECRET), {
        ticket: ticket, redirect_uri: CALLBACK,
        code_verifier: pending.verifier })
    require(HTTP == 200 and validJsonSchema(data))
    require(data.issuer == EXPECTED_ISSUER)
    require(data.client_id == CLIENT_ID and data.sub != "")
    require(data.session_expires_at > nowUnixSeconds())
    account = requireEnabledLocalAccount(data.issuer, data.sub)
    createLocalSession(account, min(localExpiry, data.session_expires_at))
    redirectToAllowedLocalPage()
```

base64url 使用 -、_ 並移除 =。每次登入都產生新的隨機值；多分頁以 state 分別保存，不覆蓋同一筆 verifier。原子取出失敗、兌換逾時或重複回呼時，重新發起登入，不能把舊票券當成功。

HTTP 兌換範例

```
POST /api/sso/v1/redeem HTTP/1.1
Host: sso.example.edu
Authorization: Basic BASE64_OF_CLIENT_ID_COLON_SECRET
Content-Type: application/json

{"ticket":"CALLBACK_TICKET", "redirect_uri":"https://app.example.edu/sso/callback",
 "code_verifier":"SAVED_VERIFIER"}
```

> 範例字串均為占位符，不符合正式票券長度；需代入當次實際值。JSON 兌換端點與舊表單 /ticket/redeem 共用一次性消耗狀態，不能各兌換一次。

Web API 單一登入

JSON / 一次性票券 + PKCE；本專案自訂協定

回應範例及失敗處理

```
{
  "issuer": "https://sso.example.edu/",
  "client_id": "YOUR_CLIENT_ID",
  "sub": "stable-user-id",
  "authenticated_at": 1792368000,
  "session_expires_at": 1792369800,
  "username": "S000001",
  "name": "測試學生",
  "identity_type": "student"
}
```

時間與人員資料均為示意；username、name、identity_type 只有被授權才提供。驗證依賴與受信任中央的 HTTPS 後端通訊，這個 JSON 本身不是簽章 JWT。

情境	處理
400 invalid_request	檢查欄位、字元及長度；不要無限重送。
400 invalid_client_or_redirect	授權入口的系統未啟用或回呼不符；核對登記。
400 session_inactive	中央登入不可用；重新發起登入。
401 invalid_client	後端兌換的系統驗證失敗；核對 ID / 密鑰。
400 invalid_ticket	逾時、重放、verifier / 回呼不符或登入已失效；重新登入。
413 / 415 / 網路或服務錯誤	請求上限 8 KiB；使用 application/json，非 200 一律不建立登入。

驗收重點

- 正常登入、中央已登入與登入逾時三種情境都要測試。
- 錯誤回呼、錯誤密鑰 / 簽章、票券重放、停用系統與停用帳號必須拒絕。
- 只有允許的欄位才可使用；欄位缺少或空白要能處理。
- 本地帳號未開通或沒有業務權限時顯示拒絕頁，不自動授予管理權。
- 登入後導向不含 code / ticket 的站內頁面；日誌不留原始密鑰、票券或 Token。

> 中央與接收系統各自建立 Cookie / Session。中央登入有效可省略再次輸入帳密；接收系統仍須完成驗證。中央登出不等於所有下游同時登出，本版未實作完整跨系統單一登出。

實作核對：src/NkustSso.Server/Controllers/WebApiSsoController.cs；ApiModels/SsoAuthorizeRequest.cs；ApiModels/SsoTicketRedemptionRequest.cs；ApiModels/SsoIdentityResponse.cs；Services/LoginTicketService.cs